VANTA TRUST REGISTRY · SOC 2 TYPE II EXAMINATION REPORT

SOURCE: https://www.vanta.com/collection/soc-2 · AICPA AT-C 205 COMPLIANCE

SERVICE ORGANIZATION: Cloud Services Infrastructure Platform (CyberVault / Vanta Trust Registry)
EXAMINATION PERIOD: October 1, 2023 to March 31, 2024
INDEPENDENT CPA AUDITOR: Deloitte & Touche LLP / Vanta Auditor Network
TRUST SERVICES CRITERIA EVALUATED: Security (CC6.1-CC6.8), Availability (CC7.1-CC7.2), Confidentiality (CC6.3)
AUDITOR OPINION: UNQUALIFIED CLEAN OPINION ? NO DEVIATIONS OR MATERIAL WEAKNESSES IDENTIFIED

SECTION 1: MANAGEMENT ASSERTION & SCOPE
Management of Service Organization asserts that the controls described were suitably designed and operating effectively throughout the 6-month observation period to satisfy the AICPA Trust Services Criteria.

SECTION 2: AUDITOR INDEPENDENT TESTING & EVIDENCE VERIFICATION

1. CRITERION CC6.6 (DATA ENCRYPTION AT REST & TRANSIT - RULE-SEC-001):
? Control Requirement: Data at rest must be encrypted with AES-256; data in transit must enforce TLS 1.3 encryption.
? Testing Performed: Inspected AWS KMS master key policies and cloud production bucket attributes. Sampled 100 S3 buckets and EBS volumes.
? Result: Operating effectively. 100% of tested volumes enforce AES-256. All external endpoints negotiate TLS 1.3 exclusively.

2. CRITERION CC6.1 (PRIVILEGED MULTI-FACTOR AUTHENTICATION - RULE-SEC-002):
? Control Requirement: Administrative access to cloud infrastructure mandates hardware-backed Multi-Factor Authentication (FIDO2 / YubiKey).
? Testing Performed: Examined Okta and AWS IAM single sign-on logs for all 42 administrative personnel across 180 days.
? Result: Operating effectively. Single-factor login is systematically blocked. Zero unauthorized bypass events detected.

3. CRITERION CC7.2 (INCIDENT ESCALATION & 72-HOUR STATUTORY NOTIFICATION - RULE-SEC-004):
? Control Requirement: Security incidents affecting customer data require operational escalation within 72 hours under GDPR Art. 33.
? Testing Performed: Inspected Jira Service Management incident queues and post-mortem retrospect reports.
? Result: Operating effectively. Zero statutory breach delays detected; average escalation time was 3.4 hours.

4. CRITERION CC6.3 (THIRD-PARTY SUBPROCESSOR DUE DILIGENCE - RULE-SEC-006):
? Control Requirement: All third-party infrastructure subprocessors must maintain current SOC 2 Type II or ISO 27001 certifications.
? Testing Performed: Verified vendor risk registry and inspected countersigned Data Protection Agreements (DPAs) for all 18 active subprocessors.
? Result: Operating effectively. 100% of subprocessors maintained active certifications and valid countersigned DPAs.